Relatório de Auditoria de Segurança Web

Alvo: example.com **Data:** 2026-10-23 15:52

Classificação	Pontuação	Problemas	Verificações OK
F	12/100	7	6

Problemas por gravidade: Crítica: 0, Alta: 3, Média: 2, Baixa: 2

Problemas encontrados e como corrigir

[Alta] Strict-Transport-Security (HSTS)

HSTS ausente ou com max-age demasiado curto (< 180 dias).

Como corrigir: Adicionar: Strict-Transport-Security: max-age=31536000; includeSubDomains

[Alta] Content-Security-Policy

CSP ausente.

Como corrigir: Definir uma CSP restritiva, por exemplo: default-src 'self'; object-src 'none'

[Alta] Redirecionamento HTTP→HTTPS

O site responde em HTTP sem redirecionar para HTTPS.

Como corrigir: Configurar redirecionamento permanente (301) de HTTP para HTTPS.

[Média] Proteção contra clickjacking

Sem X-Frame-Options nem frame-ancestors: o site pode ser embebido em iframes maliciosos.

Como corrigir: Adicionar X-Frame-Options: DENY (ou CSP frame-ancestors 'none')

[Média] X-Content-Type-Options

Header ausente ou inválido.

Como corrigir: Adicionar: X-Content-Type-Options: nosniff

[Baixa] Referrer-Policy

Header ausente: URLs completos podem vazar para terceiros.

Como corrigir: Adicionar: Referrer-Policy: strict-origin-when-cross-origin

[Baixa] Permissions-Policy

Header ausente: funcionalidades do browser (câmara, microfone, localização) não restritas.

Como corrigir: Adicionar: Permissions-Policy: camera=(), microphone=(), geolocation=()

Verificações aprovadas

OK — Certificado válido e confiável — Cadeia validada (emissor: SSL Corporation).

OK — Validade do certificado — Expira em 63 dias.

OK — Versão do protocolo TLS — Negociado TLSv1.3.

OK — Cifra negociada — Cifra: TLS_AES_256_GCM_SHA384.

OK — Divulgação de versões — Sem versões de software expostas.

OK — Cookies — O site não define cookies na página inicial.

Esta auditoria é automatizada e não substitui um teste de intrusão. Cobre configuração de headers HTTP, cookies e TLS observáveis externamente na página inicial.